

Auditoria Informática

Es el conjunto de procedimientos y técnicas para evaluar y controlar un sistema informático con el fin de verificar si sus actividades son correctas de acuerdo a las normativas.

La **auditoria** es la revisión y comprobación de un ente jurídico, económico, exponiendo:

- Situación actual
- Debilidades
- Disfunciones
- Recomendaciones
- Balances de cuentas, de resultados, estados financieros
- Sistemas de Control de Gestión
- Estado de los activos de la empresa

Tipos de Auditoria Informática

Puede ser **Externa** o **Interna**

Una auditoria es **Interna** cuando lo hace gente de la propia empresa, pero tiene un gran problema y es la **dificultad de existencia** que es justamente la posibilidad de poca independencia y la confianza.

Es como si yo mismo me auditara que no soy un boludo. No da

También puede ser **externa** que es cuando justamente viene un consultor externo a ejecutarla, y sirve como crecimiento con la empresa. Hay muchas empresas que dan consultoría sobre estos temas.

No son **excluyentes**, es decir podemos utilizar una y otra a la vez inclusive en el mismo tiempo.

La auditoría informática verifica la correcta autorización y uso de los recursos informáticos, no ve el fraude económico; sino lo que sucede desde una computadora y desde el sentido amplio.

Objetivo Tácito y Fundamental

La operatividad es esencial para la auditoria, y es necesario que mientras se realice, funcione minimamente la organización como venia anteriormente.

La operatividad se consigue con:

- **Controles técnicos generales**

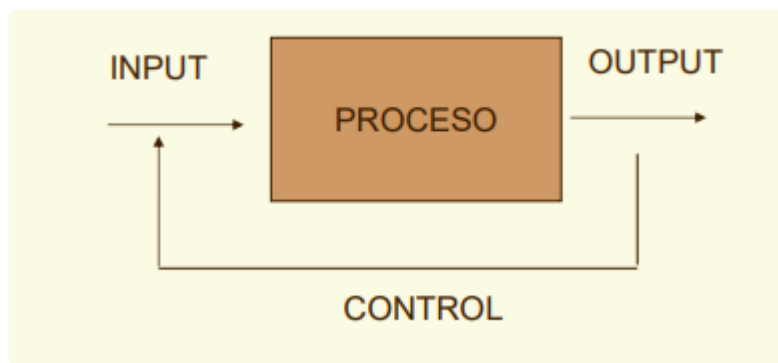
- Verificar compatibilidades de funcionamiento del SO
- Del software
- De los subsistemas
- Del Hardware y del Soft

- **Controles técnicos específicos**

- Parámetros locales
- Uso de disco
- Parámetros y asignación de memoria

Auditoria Inf de Explotación

La explotación informática se ocupa de producir resultados informáticos de todo tipo, listados impresos, ficheros soportados magnéticamente para otros informáticos, ordenes automatizadas para lanzar o modificar procesos industriales, etc. Se puede considerar como una fabrica con ciertas peculiaridades.



Se analiza la forma en que se captura la información (input)

Se audita las normas de entrega de aplicaciones por parte del desarrollo, verificando su cumplimiento y su calidad de interlocutor único; muestreos selectivo de aplicaciones explotadas.

Se analiza como se prepara, se lanza y se sigue la producción diaria; la explotación informática ejecuta los procesos en batch o en real time; se encarga del mantenimiento, control y registro de las incidencias.

???? no enitenod esto

Revisión de Controles de la Gestión Informática

Verifica las normas existentes y su coherencia con las de la empresa.

- **Normas generales de la Instalación**

- Verifica las areas y sus normativas, una normativa de un área no puede ir en contra

de una normativa general. Controlando y registrando las que no tengan normativas.

- **Procedimientos Generales**
 - Existencia en los sectores más importantes.
- **Procedimientos Específicos** Existencia en las áreas más importantes

La existencia de ambos tipos de procedimientos debe reflejar la subordinación a las normas de la organización que los comprende.

Objetivos específicos

- Auditoria del funcionamiento y eficiencia del centro de control de procesos en lote en el departamento de explotación
- Auditoria del cumplimiento de controles de distribución de resultados impresos a usuarios finales
- Auditoria de separación de entornos. Desarrollo de proyectos, explotación, centro de información
- Planes de contingencia
- Controles de acceso

Es importante definir el alcance de la auditoria, es definir el límite y el entorno, si la verificación será total o parcial, las muestras y fronteras.

Característica de la auditoría informática

Desde el punto de vista de la utilidad económico empresarial.

Hay que invertir en información; que esto reportará en beneficios.

Existen varios tipos de auditorias que nos pueden ayudar, como la auditoria Inf. de la Inversión, Inf de la Seguridad e Inf de la Organización.

Estas son auditorias globales de auditorias parciales como la de desarrollo, de explotación, de control de calidad, recepción de datos y entrega de información.

Tendencias

Es importante poder destacar lo siguiente:

- Que modelo de organización informática tenemos
- A quien tenemos como usuario final y si cumplimos con las necesidades que el requiere
- Entornos nuevos que cambiaron velozmente
- Tipos de usuarios finales (Informáticos y No Informáticos)

Solución de la Auditoria Informática

- Analizar si el modelo elegido cumple con los fines y si acerca a los Objetivos de la empresa
- Analizar el grado de facilidad con que cumple los objetivos.
- Analizar la economía del Modelo, garantizando en lo posible que el que tenemos es el más eficiente y eficaz para los objetivos perseguidos y que cualquier otro tiene un costo igual o superior al nuestro
- Multiplicidad de centros de procesos
- Descentralización de datos
- Redundancia e Inconsistencia.

Si cualquier cosa es útil para los fines, también lo es.

Síntomas de Necesidad de Aud Informática

- Descordinación y Desorganización
 - No coinciden los objetivos de la informática con el de la organización
 - Los estándares de productividad se desvian sensiblemente de los promedios conseguidos normalmente
- Mala imagen e Insatisfacción de los Usuarios
 - No se atienden las peticiones de cambio de los usuarios
 - No se reparan las averías de HW ni se resuelven las incidencias en los plazos razonables
 - No se cumplen plazos de entregas (Aplic. Criticas)
- Debilidades economica financieras
 - Incremento desmesurados de Costes
 - Necesidad de justificación de inversiones informaticas
 - Desviaciones presupuestarias significativas
 - Costes y plazos de nuevos proyectos
- Inseguridad, Evaluación del Nivel de Riesgos
 - Seguridad Lógica - Fisica
 - Confidencialidad
 - Continuidad del Servicio
 - Centro de Proceso de Datos Fuera de Control

Herramientas y Técnicas para la auditoría informática

- Cuestionarios
- Entrevistas
- Checklist Binarios o de Rango

- Trazas y/o Huellas (logs)
- Software de Interrogación

Tipos y clases de auditorías informáticas

Áreas Generales y Específicas

Pueden ser (Áreas generales):

- Aud. Inf. de Usuario: *Proyectada al exterior*
- Aud Inf. de Actividades Internas: *La cotidiana real*
- Aud. Inf. de Dirección: *Interpreta las necesidades de la compañía. Coordina entre el área de informática y los usuarios*
- Aud de Seguridad

Así mismo, armamos la siguiente matriz.

Áreas Generales Áreas Específicas		Administra cion		
	Interna	Direccion	Usuario	Seguridad
Desarrollo				
Explotacion				
Sistemas				
Comunicaciones				
Seguridad				

Metodología de Trabajo de la Auditoría Informática

El método de trabajo del auditor tiene las siguientes etapas:

1. Alcance y objetivos de la Aud. Inf.
2. Estudio inicial del entorno auditable
3. Determinación de los recursos necesarios para realizar la auditoría
4. Elaboración del plan y de los programas de trabajo
5. Actividades de la auditoría

6. Confección y redacción del Informe Final

7. Redacción de la Carta de Introducción o Carta de Presentación del Informe Final.

Definición de Alcances y Objetivos

El alcance de la auditoría expresa los límites de la misma. Debe existir un acuerdo entre los auditores y el cliente sobre las funciones, las materias y las organizaciones a auditar. Para acotar el trabajo, es beneficioso que ambas partes expresen las excepciones del alcance, es decir cuales materias, funciones u organizaciones no van a ser auditadas. Los alcances y excepciones deben estar bien detallados para el informe final.

Las personas que realicen la auditoria deben conocer con exactitud los objetivos de su tarea; y comprender los deseos y pretensiones del cliente, de forma que las metas fijadas pueden ser cumplidas.

Definidos los objetivos (específicos), estos se añaden a los objetivos generales y comunes de toda auditoría informática; la operatividad de los sistemas y los controles generales de gestión informática.

Paso a paso de la metodología de la Aud Inf. (Skip?)

Dejo esto por aquí, pero no sé; es muy raro todo... No se, capaz que sirve para chamuyar

Estudio Inicial

De parte de la organización necesitaremos el **organigrama**, como están constituidos los **departamentos**, como funcionan las **relaciones jerárquicas y funcionales entre órganos de la organización**; además como funcionan los **flujos de información**, (vertical, horizontal, oblicuas); la **número de puestos de trabajos** y la cantidad de **personas por puestos de trabajo**. Es un parámetro a considerar muy importante.

Si pide algo aquí se puede dar el ejemplo que dió la profe de calidad

Entorno Operacional

Hay que tener una referencia sobre el entorno en el que nos desarrollaremos.

Entre lo que tendremos que saber es la **situación geográfica de los sistemas**, es decir donde están ubicados; como están ubicados y demás. Además de conocer la **arquitectura y configuración de hardware y software**, si existen varios equipos, como están configurados; como es la compatibilidad, etc.

El **inventario de hardware y software**; como están las pcs, que pc tienen, que software tienen; todo esto es importante para conocerlo bien.

Además de las **comunicaciones y redes de comunicaciones** de la propia organización.

Aplicaciones, db y archivos

El volumen, la antigüedad y la complejidad de las aplicaciones.

La metodología de diseño; la existencia de alguna metodología específica para desarrollar.

La documentación, si esta es adecuada, vieja, o no existe.

La cantidad y complejidad de las DB y los ficheros, estadísticas de accesos, para q, queries, schemas, etc.

Estos datos proporcionan una visión aceptable de las características de la carga informática.

Recursos de la aud inf

Podemos necesitar los **recursos materiales** que en su mayoría son proporcionados por el cliente; las herramientas de software propias del equipo que utilizan en el sistema auditada; por lo que a veces hay que convenir fechas y horas con el cliente; estos recursos materiales pueden ser de 2 tipos:

- **Recursos materiales de software** como programas propios de la auditoria.
- **Recursos materiales de hardware** los que necesite para ser proporcionados por el cliente; por ejemplo las pc del auditado; por eso hay que convenir, tiempos, espacio, etc.

Recursos humanos

La idea es que tengas la capacidad de tener los roles estos q dice aqui, pero es mucho inventense algo q suene bien y esta bien creo

Un crack en informatica, un tecnico en informatico, un tecnico en org, un tec en costes; un experto en db y un experto en proyectos

Profesión	Actividades y conocimientos deseables
Informático Generalista	Con experiencia amplia en ramas distintas. Deseable que su labor se haya desarrollado en Explotación y en Desarrollo de Proyectos. Conocedor de Sistemas.
Experto en Desarrollo de Proyectos	Amplia experiencia como responsable de proyectos. Experto analista. Conocedor de las metodologías de Desarrollo más importantes.
Técnico de Sistemas	Experto en Sistemas Operativos y Software Básico. Conocedor de los productos equivalentes en el mercado. Amplios conocimientos de Explotación.
Experto en Bases de Datos y Administración de las mismas.	Con experiencia en el mantenimiento de Bases de Datos. Conocimiento de productos compatibles y equivalentes. Buenos conocimientos de explotación
Experto en Software de Comunicación	Alta especialización dentro de la técnica de sistemas. Conocimientos profundos de redes. Muy experto en Subsistemas de teleproceso.
Experto en Explotación y Gestión de CPD'S	Responsable de algún Centro de Cálculo. Amplia experiencia en Automatización de trabajos. Experto en relaciones humanas. Buenos conocimientos de los sistemas.
Técnico de Organización	Experto organizador y coordinador. Especialista en el análisis de flujos de información.
Técnico de evaluación de Costes	Economista con conocimiento de Informática. Gestión de costes.

3

Elaboración del plan y de los programas de trabajo

El plan se elabora teniendo en cuenta los siguientes criterios:

1. Si la revisión debe realizarse por áreas generales o áreas específicas. En el primer caso es más compleja y cara.
2. Si la auditoría es global, de toda la informática o parcial; el volumen determina la cantidad de auditores necesarios; y las especialidades necesarias del personal

La idea es que en el plan:

- No se consideren Fechas específicas
- Se establecen los recursos y esfuerzos globales que se necesitarán
- Las prioridades de materias auditables de acuerdo, con las prioridades del cliente
- La disponibilidad de los recursos para la revisión futura
- Las tareas a realizar por cada integrante
- Todas las ayudas del auditor ha de recibir

Cuando el plan esta listo, se procede a la programación de actividades, esta debe permitir realizar modificaciones si es necesario.

Actividades de la aud inf

1. Técnicas de trabajo

1. Analisis de la información recabada del auditado
2. Análisis de la información propia
3. Cruzamiento de las informaciones anteriores
4. Entrevistas
5. Simulación
6. Muestreos

2. Herramientas

1. Cuestionarios general
2. Cuestionario checklist
3. Estándares
4. Monitores
5. Simuladores
6. Paquetes de auditorias
7. Matrices de riesgo

Informe final

Se deben redactar todos esos borradores parciales en un informe final, que son los elementos de contraste entre opinión del auditor y el auditado y que pueden descubrir fallos de apreciación en el auditor.

La **estructura del informe final**

Comienza con la fecha de comienzo de la auditoría y la fecha de redacción del mismo, incluyendo los nombres del equipo auditor y los nombres de todas las personas entrevistadas con indicaciones, responsabilidades y puestos de trabajos.

Se definirán los **objetivos y alcance de la auditoría**

Se **enumerarán los temas considerados**

Cuerpo Expositivo

Por cada tema se seguirá el siguiente orden:

1. Situación actual

1. Si es una auditoria regular, entonces se mostrará como es la evolución de la misma.

2. Tendencias

1. Se buscarán parámetros que permitan establecer las tendencias futuras.

3. Puntos débiles y amenazas

4. Recomendaciones y planes de acción

1. Es el verdadero objetivo de la auditoría informática.

5. Redacción de la Carta de Introducción o Presentación

Modelo conceptual de la exposición del informe final

El informe final solo debe describir los **hechos importantes**, los **hechos pocos relevantes o accesorios** desvía la atención del lector.

El informe debe consolidar los hechos que se describen en el mismo.

Se utiliza el término de **hechos consolidados** que es la verificación objetiva y de estar documentalmente probados y soportados. Estos hechos deben satisfacer alguno de los siguientes criterios para serlos:

1. El hecho debe poder ser sometido a cambios
2. Las ventajas del cambio deben superar a los inconvenientes derivados de mantener la situación.
3. No deben existir alternativas viables que superen al cambio propuesto
4. La recomendación del auditor sobre el hecho debe mantener o mejorar las normas y estándares existentes en la instalación

Que exista un "**hecho**" significa justamente, que existe una debilidad que debe ser corregido.

Flujo del hecho o debilidad

1. Se encontró un hecho.

1. Debe ser relevante para el auditor y para el cliente
2. Debe ser exacto y además convincente
3. No deben existir hechos repetitivos

2. Debe tener consecuencias claras.

1. Deben redactarse de modo que sean directamente deducibles del hecho

3. Mostrar la repercusión del hecho

1. Se redactarán las influencias directas que el hecho puede tener sobre otros aspectos informáticos o ámbitos de la empresa.

4. Conclusión del hecho

1. No deben redactarse conclusiones más que en los casos en que la exposición haya sido muy compleja

5. Recomendaciones del auditor informático

1. Deberá entenderse por si sola, por simple lectura.
2. Debe estar suficientemente soportada por el propio texto.
3. Debe ser concreta y exacta en el tiempo, para que pueda ser verificada en la implementación.
4. La recomendación se redacta de forma que vaya dirigida expresamente a las personas que pueden implementarla.

Carta de introducción o presentación del informe final

Tiene especial importancia porque en ella ha de resumirse la auditoría realizada, se destina exclusivamente al responsable máximo de la empresa; o a la persona que concreta el encargo o contrato de auditoría.

Por una cuestión reglamentaria, es solo una; y tendrá como máximo 4 folios; debe incluir la fecha, naturaleza, objetivos y alcance. Cuantificará la importancia de las áreas analizadas.

Proporcionará una conclusión general, concretando las áreas de gran debilidad.

Presentará las debilidades en orden de importancia y gravedad, **nunca se escriben recomendaciones**

CRMR (Computer Resource Managment Review)

(Esto lo vimos en algún otro lado pero no se donde)

Se debe destacar la posibilidad de realizar una evaluación de eficiencia de utilización de los recursos por medio del magnagement o del **ADMINISTRADOR**

Una revisión de esta naturaleza no tiene en sí misma el grado de profundidad de una auditoría informática global, pero proporciona soluciones más rápidas a problemas concretos y notorios.

En función de la definición dada la metodología CRMR es aplicable más a deficiencias y gerenciales que a problemas de tipo técnico.

Entre los **objetivos de crmr** tenemos:

- Evaluar el grado de bondad o ineficiencia de los procedimientos y métodos de gestión que se observan
- Identificar y fijar responsabilidades
- Mejorar la flexibilidad de realización actividades
- Aumentar la productividad
- Disminuir Costes
- Mejorar los métodos y procedimientos de dirección

Alcance

Se establecen tres clases.

- **Reducido** Consiste en señalar las áreas de actuación con potencialidad inmediata de obtención de beneficios.
- **Medio** Se establecen conclusiones y recomendaciones tal y como se hace en la auditoría informática ordinaria.
- **Amplio** Incluye planes de acción, aportando técnicas de implementación de las recomendaciones, a la par que desarrolla las conclusiones.

